

Guía de exposición — Centro Hogar

Guía para explicar tres temas del sistema en la defensa: **Reportes**, **Copias de seguridad (Excel)** y **Seguridad de las cuentas y la web**.

Cada sección tiene: *qué es*, *cómo funciona por dentro (simple)*, *cómo explicarlo* y *posibles preguntas del tribunal con su respuesta*.

*Idea general que conviene repetir: el sistema tiene **dos partes**. El **frontend** (la pantalla, hecha en React) es lo que ve el usuario; el **backend** (el servidor, hecho en Node + Express) es el que hace las cuentas y habla con la base de datos **MySQL**. La pantalla nunca toca la base directamente: siempre le pide los datos al backend.*

1) Sección de REPORTEES

Qué es

Es la pantalla donde el encargado o el administrador ve **cómo va el negocio**: cuánto se vendió, con qué medio de pago, qué productos se venden más y qué vendedor vendió más, en el período que elija.

Qué se ve en pantalla

- 1 **Selector de período** con botones rápidos: *Hoy*, *Esta semana*, *Últimos 7 días*, *Este mes*, *Mes anterior* y *Personalizado* (elegís fecha desde/hasta a mano).
- 2 **Tres tarjetas principales (KPIs)**:
 - **Total ventas**: cuántas ventas se hicieron.
 - **Monto total**: la plata total facturada.
 - **Ticket promedio**: cuánto se gastó en promedio por venta.
- 3 **Desglose por método de pago**: efectivo, tarjeta y transferencia, con cantidad y monto de cada uno.
- 4 **Productos más vendidos** (ranking) y **Ventas por vendedor** (ranking).
- 5 **Botones de exportación**: *Exportar Excel*, *Reporte Ventas PDF* y *Reporte Stock PDF*.

Cómo funciona por dentro (simple)

- Cuando elegís un período, el frontend le pide al backend el resumen de esas fechas.
- El backend hace las cuentas **directamente en la base de datos** con consultas SQL que **suman y agrupan** (**SUM**, **COUNT**, **AVG**, **GROUP BY**). Por ejemplo, para el monto total suma la columna **total_final** de todas las ventas del período.
- **Solo cuenta las ventas completadas** (las canceladas no entran en los números).
- Para que sea rápido aun con muchísimas ventas (la base de prueba tiene ~64.000), las consultas pesadas se ejecutan **en paralelo** y el panel principal guarda el resultado en memoria por un minuto (caché), así no recalcula todo a cada rato.

Cómo explicarlo (frase corta)

"La pantalla de Reportes le pide al servidor un resumen de un período. El servidor hace las sumas en la base con SQL y devuelve los totales, los rankings y el desglose por medio de pago. Todo se puede exportar a Excel o PDF."

Posibles preguntas

- **¿Los cálculos los hace la pantalla?** No. Los hace el servidor con consultas SQL; la pantalla solo muestra el resultado. Así es más rápido y seguro.
- **¿Por qué no aparece tal venta?** Porque solo se cuentan las ventas *completadas*; las canceladas se excluyen.
- **¿Cualquiera puede ver los reportes?** El panel resumen lo ven todos los usuarios; los reportes detallados solo el **administrador** y el **encargado de stock** (el vendedor no).

2) COPIAS DE SEGURIDAD (backup en Excel y CSV)

Qué es

Es la posibilidad de **descargar todos los datos del sistema** en un archivo, para guardarlos por las dudas (si se rompe la computadora, si hay que migrar a otro servidor, o simplemente para tener un respaldo).

Está en la pantalla **Ajustes** → **Copia de seguridad**, y solo puede usarla el **administrador**.

Qué se ve en pantalla

Dos botones:

- **Backup CSV (ZIP)**: descarga un **.zip** con un archivo **.csv** por cada tabla.
- **Backup Excel**: descarga un único **.xlsx** con **una hoja por cada tabla** (Ventas, Detalle de ventas, Clientes, Productos, Categorías, Movimientos de stock, Usuarios, Roles, Métodos de pago, etc.).

El nombre del archivo incluye la **fecha** del día (ej: **centro-hogar-backup-2026-06-27.xlsx**).

Cómo funciona por dentro (simple)

- El backend lee **todas las tablas** de la base y arma el archivo.
- El **Excel se genera con formato profesional** (librería *ExcelJS*): encabezado de color, filas alternadas (efecto zebra), ancho de columna automático, primera fila congelada, filtros y formato de números/fechas (la plata se muestra con separador de miles, las fechas como fecha).
- Detalle de **seguridad importante**: la columna de **contraseñas (password_hash)** se **excluye** del backup. Aunque alguien abra el Excel, no hay contraseñas adentro.

El "respaldo automático antes de borrar" (lo más interesante de contar)

En Ajustes también está la **Limpieza de ventas antiguas**: el administrador puede borrar ventas viejas (por ejemplo, más de 2 años) para aliviar la base. Esto es **peligroso** (borra datos), así que tiene dos protecciones:

- 1 **Doble confirmación**: hay que escribir la palabra **"ELIMINAR"** a mano para habilitar el botón.
- 2 **Copia de respaldo automática primero**: antes de borrar nada, el sistema **genera y descarga un Excel con todas las ventas que se van a eliminar** (con su detalle). **Solo si esa copia se descarga bien, recién ahí borra**. Si la copia falla, no se borra nada.

Esto demuestra una buena práctica: nunca borrar sin antes respaldar.

Cómo explicarlo (frase corta)

"Desde Ajustes el administrador puede descargar toda la base en Excel o CSV, con las contraseñas excluidas por seguridad. Y si decide borrar ventas viejas, el sistema primero descarga automáticamente una copia en Excel de lo que va a borrar; solo si esa copia sale bien, ejecuta el borrado."

Posibles preguntas

- **¿Por qué dos formatos (CSV y Excel)?** El CSV es universal y liviano (sirve para reimportar o procesar); el Excel es más cómodo de leer para una persona, ya viene con formato.
- **¿El backup tiene las contraseñas?** No, se quitan a propósito.
- **¿Y si borro ventas por error?** No pasa, porque antes de borrar se descarga una copia en Excel de esas ventas, y además hay que escribir "ELIMINAR".

3) SEGURIDAD de las cuentas y de la web

Conviene dividirlo en dos: **seguridad de las cuentas** (login, contraseñas, roles) y **seguridad de la aplicación web** (protecciones del servidor).

A. Seguridad de las cuentas

Contraseñas cifradas (lo más importante). Las contraseñas **nunca se guardan tal cual**. Se guardan "hasheadas" con **bcrypt** (factor de costo 12). El hash es un proceso de **una sola vía**: se puede verificar si una contraseña es correcta, pero **no se puede leer la contraseña original**, ni siquiera teniendo acceso a la base de datos.

Frase para decir: "Si alguien robara la base, no obtendría ninguna contraseña, porque están cifradas con bcrypt de forma irreversible."

Inicio de sesión con token (JWT). Cuando el usuario entra bien, el servidor le entrega un **token** (una credencial temporal firmada) que **vence a las 8 horas**. En cada pedido el usuario manda ese token, y el servidor lo verifica. Si está vencido o es falso, lo rechaza.

Roles y permisos. Hay tres roles: **administrador**, **encargado de stock** y **vendedor**. Cada zona del sistema valida el rol:

- El **administrador** puede todo (usuarios, backups, borrar ventas, reportes).
- El **encargado de stock** ve reportes y maneja productos/stock.
- El **vendedor** registra ventas y consulta el catálogo, pero **no** entra a usuarios ni a backups.

Cuentas que se pueden desactivar. Un usuario puede marcarse como **inactivo**; a partir de ahí no puede iniciar sesión, aunque sepa su contraseña.

Recuperación de contraseña.

- Si un usuario la olvida, el **administrador** se la restablece desde la pantalla de Usuarios.
- Si el **administrador** olvida la suya y no hay otro admin, hay un **script de emergencia** que corre en el servidor (**reset-password**) y la restablece directamente en la base. Solo lo puede usar quien tiene acceso físico/remoto al servidor.

B. Seguridad de la aplicación web (protecciones del servidor)

- **Contraseñas y secretos fuera del código:** la clave de la base de datos y la clave que firma los tokens están en un archivo `.env` que **no se sube al repositorio** (queda solo en el servidor).
- **Consultas preparadas (anti SQL Injection):** todas las consultas a la base usan **parámetros (?)** en vez de pegar texto del usuario dentro del SQL. Eso evita el ataque clásico de "inyección SQL".
- **Validación de datos con Zod:** antes de procesar cualquier formulario, el servidor valida que los datos tengan el formato correcto (email válido, contraseña de largo mínimo, etc.). Si no, los rechaza.
- **Límite de intentos (rate limiting):** el servidor limita cuántos pedidos acepta por minuto. En el **login** es más estricto: **8 intentos cada 15 minutos**, para frenar ataques de **fuerza bruta** (probar contraseñas una tras otra).
- **Helmet:** agrega automáticamente **cabeceras de seguridad** a las respuestas HTTP (protege contra varios ataques comunes del navegador).
- **CORS restringido:** el servidor solo acepta pedidos que vengan de la dirección del propio frontend, no de cualquier sitio.
- **Todo lo sensible pide token y rol:** ninguna acción importante se puede hacer sin estar logueado y sin tener el rol adecuado.

Cómo explicarlo (frase corta)

"La seguridad está en capas: las contraseñas se guardan cifradas con bcrypt; el acceso usa un token que vence; cada rol ve solo lo suyo; y el servidor se protege con límite de intentos en el login, validación de datos, consultas preparadas contra inyección SQL y cabeceras de seguridad."

Posibles preguntas

- **¿Dónde se guardan las contraseñas?** En la base, pero **cifradas con bcrypt**; no se pueden recuperar en texto plano.
- **¿Qué pasa si alguien intenta adivinar la contraseña probando muchas?** El login bloquea después de 8 intentos en 15 minutos.
- **¿Cómo evitas la inyección SQL?** Usando consultas con parámetros (prepared statements), nunca concatenando texto del usuario en la consulta.
- **¿Qué es el token y por qué vence?** Es la credencial que prueba que el usuario ya inició sesión; vence a las 8 horas para que, si se filtra, no sirva para siempre.
- **¿Un vendedor puede entrar a los reportes o a los backups?** No, esas zonas están restringidas por rol a administrador (y encargado para reportes).

Resumen de una línea por tema (para cerrar)

- **Reportes:** el servidor hace las sumas en SQL y devuelve totales, rankings y desglose por medio de pago; exportable a Excel y PDF.
- **Backups:** descarga de toda la base en Excel/CSV (sin contraseñas), y copia automática antes de borrar ventas viejas.
- **Seguridad:** contraseñas con bcrypt, acceso por token que vence, permisos por rol, y el servidor protegido con rate limit, validación, consultas preparadas y helmet.